

CVE Prioritization Automation — One Pager

Purpose

Automates risk-based prioritization of vulnerabilities using three trusted sources: CISA KEV (known exploited), EPSS (likelihood of exploitation), and NVD CVSS (severity). Outputs an explainable priority score, a CSV for analysis, and a chart for quick review.

How It Works

- 1 Fetch EPSS daily scores; normalize to numeric.
- 2 Fetch CISA KEV catalog; mark CVEs present in the list as KEV=1.
- 3 Fetch NVD CVEs (recent window); extract CVSS v3.x base scores.
- 4 Join data and compute $\text{Priority} = (\text{KEV} \times 100) + (\text{EPSS} \times 50) + (\text{CVSS} \times 5)$.
- 5 Sort descending and save results to CSV + Top 15 chart.

Outputs

- `artifacts/figures/priority.csv` — full table with CVE, KEV flag, EPSS, CVSS, Priority.
- `artifacts/figures/priority_chart.png` — bar chart of top 15 CVEs by Priority.

Run Instructions

From `C:\lgm-interview-capstone\artifacts\scripts` in a Python virtual environment: 1) `python -m venv .venv` 2) `.\venv\Scripts\Activate.ps1` 3) `python -m pip install -r requirements.txt` (or: `pip install pandas matplotlib requests`) 4) (Optional) Set `$env:NVD_API_KEY=""` 5) `python .\cve_prioritizer.py`

Interpretation Guide

- High Priority with KEV=1 → patch immediately (actively exploited).
- High EPSS but moderate CVSS → watch closely; prioritize if asset is internet-exposed.
- High CVSS but EPSS≈0 and not KEV → severity-only risk; defer if compensating controls exist.

Limitations & Next Steps

- NVD API rate limits — use an API key for broader time windows.
- No asset context — join CSV with your vulnerability scans/CMDB to focus on affected assets.
- Score is intentionally simple — tune weights to match your environment and SLAs.